



ACTIVIDAD 17 - EVALUACIÓN DE VULNERABILIDADES CON CVSS V3.1

CON V



15 DE MAYO DE 2026

Edwin Admael Castillo Gómez	181700
Carlos René Castillo Olvera	182033
Diego Osvaldo Hernández Fernández	182217
Tristan Rivera MagdalenaYesenia	174702

1. Objetivos

Objetivo General

Aplicar el modelo CVSS v3.1 (Common Vulnerability Scoring System) para evaluar la gravedad de vulnerabilidades reales, interpretando correctamente sus métricas base y justificando la priorización del riesgo en un contexto organizacional.

Objetivos Específicos

- Identificar y comprender las métricas base de CVSS v3.1: Attack Vector (AV), Attack Complexity (AC), Privileges Required (PR), User Interaction (UI), Scope (S), Confidentiality (C), Integrity (I) y Availability (A).
- Construir formalmente la cadena del vector CVSS a partir de un escenario técnico específico.
- Calcular e interpretar la puntuación de riesgo resultante para priorizar de manera estratégica las acciones de mitigación.

2. Escenario

Se evalúa una vulnerabilidad detectada en un sistema web interno de la organización, cuyas características técnicas se desglosan a continuación:

1. Vector de Ataque
2. Complejidad del Ataque
3. Privilegios Requeridos
4. Interacción del Usuario
5. Alcance (Scope)
6. Impacto en la Tríada CIA:
 - Confidencialidad: Bajo
 - Integridad: Bajo
 - Disponibilidad: Bajo

3. Cadena

Vector String -

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

4. Interpretación Técnica y Análisis de Riesgo

A pesar de requerir privilegios elevados, esta vulnerabilidad representa un riesgo latente debido a la baja complejidad de su explotación. Los vectores de amenaza potenciales incluyen:

- **Insiders Maliciosos:** Usuarios internos con roles de administración que abusen de sus capacidades de acceso.
- **Movimiento Lateral o Escalada previa:** Atacantes externos que ya hayan comprometido el perímetro y obtenido credenciales legítimas mediante técnicas de phishing, reutilización de contraseñas o fuerza bruta.

Análisis de Impacto:

El impacto clasificado como Bajo en la tríada CIA determina que el alcance del daño está acotado. Específicamente, la filtración de datos se limita a información no sensible; las alteraciones al sistema no afectan la lógica central del negocio; y cualquier interrupción en la disponibilidad se traduce en una degradación menor del servicio, sin provocar caídas críticas en la infraestructura interna.

5. Clasificación

- Puntuación Base: 4.7
- Severidad: Media (Rango: 4.0 a 6.9)

Base Score		4.7 (Medium)
Attack Vector (AV)	Scope (S)	
☒ Network (N) ☐ Adjacent (A) ☐ Local (L) ☐ Physical (P)	☒ Unchanged (U) ☐ Changed (C)	
Attack Complexity (AC)	Confidentiality (C)	
☒ Low (L) ☐ High (H)	☐ None (N) ☒ Low (L) ☐ High (H)	
Privileges Required (PR)	Integrity (I)	
☐ None (N) ☐ Low (L) ☒ High (H)	☐ None (N) ☒ Low (L) ☐ High (H)	
User Interaction (UI)	Availability (A)	
☒ None (N) ☐ Required (R)	☐ None (N) ☒ Low (L) ☐ High (H)	

Conclusión

La vulnerabilidad se clasifica formalmente como de Riesgo Medio. De acuerdo con las mejores prácticas de gestión de vulnerabilidades, se recomienda su remediación mediante un plan programado dentro del ciclo normal de parches de seguridad. No requiere una respuesta de emergencia (como un riesgo Alto o Crítico), pero no debe ignorarse, ya que podría ser utilizada como un eslabón secundario en una cadena de ataque (exploit chaining).